CYBERSECURITY ENGINEERING

Enterprise Zero Trust Security Architecture

HL-CYB-001 | Advanced engineering assignment

Design and evaluate an isolated lab that gives staff access to the resources their roles require.

Current status: Planning documents and repository checks exist. Lab implementation is PLANNED; operational controls are NOT TESTED. Owner user acceptance testing (UAT) is PENDING.

Assignment contents

1. Project Overview 2

2. Project Objectives 2

3. Project Scope 2

4. Technologies and Resources 3

5. Project Requirements 3

6. Expected Deliverables 4

7. Implementation Approach 5

8. Success Criteria 5

9. References 6

1. Project Overview

A synthetic organization, Purple Eye, needs to support three roles: an analyst reads reports, an engineer maintains a test application, and an administrator manages infrastructure. Each person must complete approved work without receiving unnecessary access to other systems. Include an unauthorized user and a remote user whose access will be revoked.

Build a repeatable place to evaluate these access decisions, investigate events and recover services before considering an enterprise deployment. Apply Zero Trust: verify identity and permission for each resource instead of trusting network membership. Combine identity, device controls, network restrictions and application permissions. Use synthetic people and data throughout.

2. Project Objectives

By completing the assignment, the student will:

1. Translate business roles into an inventory, access matrix, architecture and measurable acceptance tests.
2. Build six isolated security zones and demonstrate permitted and denied workflows without changing home or production networks.
3. Establish lab identities, endpoint controls and certificate services with documented recovery.
4. Compare two resource-scoped remote-access approaches and measure access revocation.
5. Correlate security events, automate two repeatable operations and verify a timed restore.
6. Explain evidence, tradeoffs and remaining risks in a professional submission and reviewed public repository.

These learning outcomes span risk management, asset security, architecture, networks, identity, assessment, operations and secure automation. They are educational objectives, not certification credit.

3. Project Scope

Implement a virtual-first lab with identity and certificate services, Windows and Linux endpoints, a synthetic application, central logging, separate remote-access pilots, automation and recovery. The architecture defines zones, capacity and allowed flows; the security requirements define threats, controls and standards mappings.

Boundaries: Start offline. Keep lab identities, credentials, trust and remote-access environments separate. No production trust, federation, identity synchronization, corporate Microsoft 365 connection, credential reuse, PE-DAP code, customer data, corporate website testing, production hosting integration or public service exposure is permitted. Never probe home or production networks; use policy inspection, passive observation and lab-owned mock targets. Isolated Internet access needs its own approved design.

High availability, clustering and compliance certification are excluded. Document the limits of a single host, nonresilient identity services, device attestation, certificate-key protection and unstaffed monitoring. No purchase, subscription or software license selection is authorized.

4. Technologies and Resources

Proposed tools are Proxmox VE for virtualization; OPNsense for network policy; Windows Server Evaluation with Active Directory, Domain Name System (DNS) and Group Policy; Windows/Linux endpoints; and public key infrastructure (PKI) with an offline root certificate authority (CA) and separate issuer. Evaluate Tailscale and Twingate sequentially. Use Windows Event Collector and Linux/syslog for logging, and PowerShell, Python or Ansible for the two automation operations. Git, GitHub and documentation-only continuous integration (CI) support publication.

Owner-described resources are a Dell Precision 5820 (Xeon W-2125, 80 GB RAM, 512 GB NVMe), Lenovo Xeon laptop (119 GB RAM), HP 410-019 (16 GB RAM, at least 250 GB storage), test laptops and Google Wifi. These are unverified descriptions. Confirm ownership, processor/virtualization support, interfaces, disk contents, usable capacity, console access and backup suitability before use. Initial guest ceilings are 36 GiB RAM and 248 GiB disk; reserve at least 12 GiB host RAM and 80 GiB free disk space. The capacity ledger governs sizing.

Verify supported versions, lawful evaluation terms, recovery access and official media at stage entry. Alternative technologies require a recorded design change that preserves the learning outcomes. See the glossary for technical terms.

5. Project Requirements

All lab requirements remain PLANNED. Retain these IDs in configurations, tests and evidence. The test plan retains the detailed procedures and requirement-to-test mapping; the acceptance criteria define stage gates and exceptions.

Table 1. Project Requirements

ID	Required outcome and measurement	Tests
R01	No production trust, identity synchronization, credential reuse, customer data or path into protected home/production assets. Verify configuration and denial against lab-owned mock boundaries.	T01, T02
R02	Verify processor/virtualization, interfaces, disk ownership/free space and recovery. Keep initial guest disk/RAM within 248 GiB/36 GiB and measured capacity.	T03
R03	Restrict hypervisor/firewall administration to a dedicated lab path, with a named administrator, supported multifactor authentication (MFA), least privilege and tested emergency console access.	T04
R04	Provide at least six trust zones. Record owner, direction, destination, service and justification for every inter-zone permit; deny all unmatched traffic.	T05, T06
R05	Create a separate `ad.lab.test` forest, lab DNS and Group Policy; at least six synthetic standard users in three role groups plus two separate privileged accounts; no external trust.	T07, T08
R06	Baseline at least one supported Windows member endpoint and one supported Linux endpoint. Enable host firewalls, record updates and prevent ordinary-user local administration.	T09
R07	Use an offline standalone root and separate online issuing CA. Issue a scoped lab Transport Layer Security (TLS) certificate; verify trust, expiration and revoked-certificate rejection in a selected supported application.	T10, T11

ID	Required outcome and measurement	Tests
R08	Test at least twelve explicit role/resource allow/deny cases, including same-zone controls. Measure resource-access revocation against a fifteen-minute target after policy change.	T06, T12
R09	Evaluate Tailscale and Twingate sequentially in separate lab-only environments. Each pilot needs scoped identities/devices, MFA, one named resource, denied-user and revocation tests; no subnet-wide or exit-node exposure.	T13, T14
R10	Collect firewall, hypervisor, directory, Windows endpoint, Linux endpoint and remote-access events. At least 95% of twenty synthetic events must be searchable within five minutes; clock offsets must be at most two seconds. Prove capacity for a thirty-day retention design.	T15, T16
R11	Individually review all public artifacts and published history. Exclude secrets, actual internal addresses, sensitive identities, production exports, proprietary source and raw evidence.	T00, T17
R12	Deliver two bounded automation operations with reviewed targets and rollback. A repeat run must make zero unintended changes; review check/diff output privately.	T18
R13	Encrypt off-compute backups of representative identity/application material. Demonstrate an isolated restore with proposed recovery point objective (data age) at most 24 hours and recovery time objective at most four hours. State exclusions and dependency order.	T19
R14	Execute every approved mandatory test. Pass 100% of critical and at least 95% of applicable noncritical cases, with no unresolved high-severity issue. Record owner UAT separately.	T01-T20
R15	Complete the assignment, stage guide, architecture, threat model, decisions, risks and final report. Link each achievement to reviewed evidence and resolve every local Markdown link.	T00, T20
R16	Use the public repository's main branch, controlled task branches/pull requests, read-only documentation CI, reviewed commits and exact local/remote synchronization.	T00

6. Expected Deliverables

Submit the eight files below in `docs/deliverables/`. Keep sensitive working records and raw evidence outside public Git, and submit only reviewed public-safe summaries and references.

Table 2. Expected Deliverables

Deliverable filename	File format	Expected contents
`01-Lab-Environment.xlsx`	Excel (.xlsx)	Verified hardware/software inventory, capacity, evaluation deadlines and readiness decisions (R02).
`02-Architecture-and-Network-Design.docx`	Word (.docx)	Business roles, topology, six zones, allowed flows, isolation, administration, threats, decisions and risks (R01, R03, R04, R15).
`03-Identity-and-Access-Management.xlsx`	Excel (.xlsx)	Synthetic users/groups, privileged roles, Windows/Linux baselines, twelve access cases and revocation timing (R05, R06, R08).

Deliverable filename	File format	Expected contents
`04-Zero-Trust-Implementation.docx`	Word (.docx)	Configuration summaries, certificate lifecycle, separate remote-access comparisons, two automations, rollback and backup/restore procedures with evidence links (R03, R04, R07, R09, R12, R13).
`05-Security-Monitoring.xlsx`	Excel (.xlsx)	Six-source inventory, twenty-event timing results, clock checks, retention sizing and an event investigation (R10).
`06-Testing-and-Validation.xlsx`	Excel (.xlsx)	Requirement/test/evidence matrix, expected/actual positive and negative results, second observations, recovery measurements, defects and separate owner UAT (R01, R13, R14).
`07-Troubleshooting-and-Lessons.xlsx`	Excel (.xlsx)	Problems, diagnosis, corrective actions, retests, rollback, lessons and unresolved risks (R14, R15).
`08-Final-Lab-Submission.docx`	Word (.docx)	Final assessment, deliverable/evidence index, requirement coverage, measured outcomes, limitations, public-hygiene review and GitHub/CI/synchronization record (R11, R15, R16).

Demonstrate the configured lab with reviewed evidence. Keep reusable public-safe automation/configuration files and maintained Markdown/PDF documents in their designated repository folders; link them from the eight submissions instead of copying their full content. Finalize a Markdown-only report for each authorized task. The project final report remains a template until implementation evidence exists.

7. Implementation Approach

Follow the Lab Implementation Guide in dependency order:

- **A-D:** Verify readiness, install the approved host, separate zones and enforce network boundaries.
- **E-H:** Establish directory/endpoint controls, certificate services and role-based resource access.
- **I-J:** Compare isolated remote-access pilots and complete central monitoring.
- **K-L:** Run approved validation, automate operations, prove recovery and complete the submission.

Each stage A-L requires separate owner approval identifying scope, assets, changes, validation and rollback. Disk installation also requires approval of the exact disk and backup/recovery plan. Keep online pilots pending if safe egress cannot be established. Local logging and backups start with the first installed component. Procedures and proposed commands belong in the guide.

8. Success Criteria

Assess results against the acceptance criteria, requirements and rubric. Every test needs declared synthetic targets, expected/actual results, a second observation and reviewed evidence. Positive tests prove approved work; negative tests prove denial. Mark unexecuted cases NOT TESTED. A second observation is not independent human sign-off. CI verifies documentation; owner UAT requires explicit acceptance.

Table 3. Success Criteria

Assessment area	Points	Evidence for full credit
Business analysis and governance	8	Role workflows, scope, approvals, decisions and risk ownership.
Architecture and capacity	12	Justified boundaries, sizing, dependencies and limitations.
Isolation and network enforcement	15	Default-deny rules, no protected path, positive and mock-negative results.
Directory and endpoint identity	12	Separate forest, synthetic roles, DNS/policy and Windows/Linux baselines.
PKI and certificate lifecycle	10	Offline root, scoped issuer, issuance/trust/expiry/revocation evidence.
Least privilege and resource authorization	10	Twelve cases, same-zone controls and measured revocation.
Remote-access comparison	8	Separate pilots, MFA, narrow resources and denial/revocation results.
Monitoring and audit analysis	8	Six sources, ingestion/clock targets, retention capacity and investigation.
Validation and recovery	10	Critical tests, second observations, timed restore and separate owner UAT.
Repeatable automation	4	Two reviewed operations, repeat-run evidence and rollback.
Public portfolio and final reporting	3	Sanitized evidence, working documentation/CI, synchronized Git and accurate claims.

Total: 100 points. Score each area as demonstrated, partly demonstrated or absent, with a written rationale. Planning earns no implementation credit. Production integration, secret publication or an unresolved critical safety test prevents acceptance regardless of score. Approve any scope exception and revise affected requirements, acceptance and scoring before evaluation. Report measured lab results and limits; do not claim unproven savings, production security improvements or certification.

9. References

- NIST SP 800-207: Zero Trust Architecture: resource-focused access principles.
- NIST SP 800-53 Rev. 5 and CIS Controls v8.1: educational mappings in the security requirements, not a compliance claim.
- Project reference catalog: official vendor sources; verify current versions, terms and commands before implementation.